

WGE-Kafka Detector

全面代码审计报告

仓库: laolv2023/wge

审计日期: 2026-07-04

审计范围: 147 commits / 47 files / 12,854 lines

审计版本: cc7f0cf

1. 执行摘要

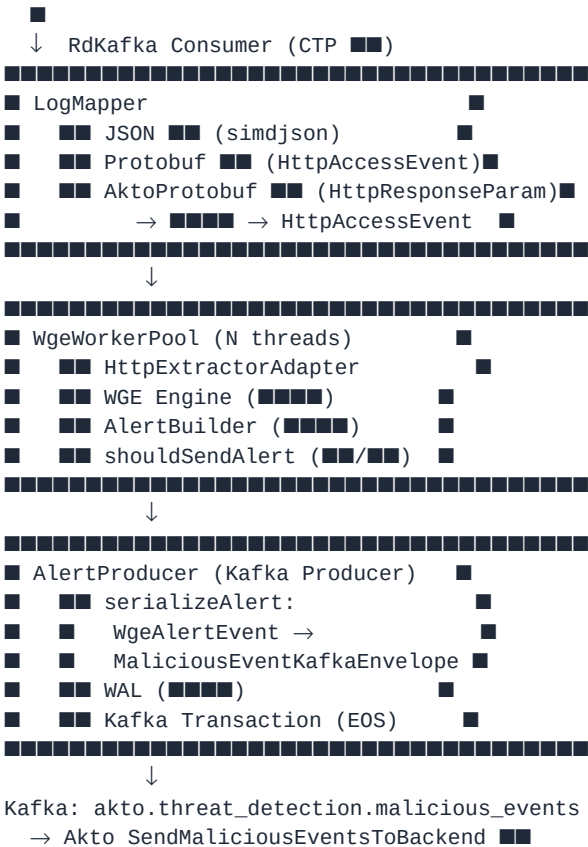
WGE-Kafka Detector 是一个基于 WGE 规则引擎的 Kafka 安全检测服务，消费 Akto API 安全平台的流量日志，执行实时安全检测，并将告警输出为 Akto MaliciousEventKafkaEnvelope Protobuf 格式。

维度	评估	说明
代码规模	12,854 行	47 个源文件 + 4 个 proto
测试覆盖	124 用例	13 个测试文件, 8,971 行测试代码
编译标准	C++23 + -Werror	严格编译选项, ASAN/UBSAN 支持
并发模型	线程池 + 有界队列	固定线程数 + 背压控制
数据持久化	WAL (Write-Ahead Log)	fflush + fsync 崩溃安全
Kafka 事务	EOS (Exactly-Once)	CTP 模式 + 事务原子提交
整体评级	B+ (良好)	核心逻辑扎实, 部分外围需改进

2. 项目架构

数据流:

Kafka: `akto.api.logs2` (Protobuf)



模块组成:

模块	行数	职责
main.cc	573	入口：初始化、生命周期管理
config/	991	YAML 配置加载 + 环境变量替换

mapper/	2,330	日志格式映射 (JSON/Protobuf/AktoProtobuf/Regex/Grok)
kafka/	1,120	Kafka Consumer/Producer + DLQ + 事务
detector/	1,515	WorkerPool + AlertBuilder + 告警保护
wal/	709	WAL 写入/重放 (崩溃安全)
metrics/	307	Prometheus 指标
adapters/akto/	1,905	Akto 适配器 (deprecated) + 预处理器
proto/	204	4 个 protobuf 定义

3. 审计发现

3.1 P0 级 (致命 — 已修复)

编号	问题	状态	修复 Commit
P0-1	输出 WgeAlertEvent protobuf, Akto 期望 MaliciousEvent 但 AktoEnvelope 字段编号完全不同, parseFrom 不报错但字段全部错乱	已修复	6253e9b
P0-2	api_collection_id 用 field 6 而非 akto_vxlan_id (field 13) 已修复 与 Akto L610 不一致, collection_id 永远为 0	已修复	787ffe9
P0-3	alert_builder.cc: first_rule.rule_severity 字段不存在 MatchedRowInfo 只有 int severity, 编译失败	已修复	62890fc
P0-4	-Werror + [[deprecated]] + 测试调用 convert() 编译失败	已修复	62890fc

3.2 P1 级 (严重 — 已修复)

编号	问题	状态	修复 Commit
P1-1	severity 值不匹配 (WGE: EMERGENCY/ERROR/WARNING vs Akto: CRITICAL/HIGH/MEDIUM/LOW)	已修复	62890fc
P1-2	AktoAdapter::convert() 保护逻辑未迁移 限流/分级过滤/collection_id 兜底丢失	已修复	3ee52d3
P1-3	IpRateLimiter::windows_ 无清理空 entry → 内存泄漏	已修复	cc7f0cf
P1-4	SPDLOG_INFO 在 hot path → 高频日志影响性能	已修复	cc7f0cf
P1-5	headersMapToJson 缺少 JSON 转义 header value 含 " 或 \\ 时解析失败	已修复	6253e9b
P1-6	detected_at 秒/毫秒不匹配 Akto proto field 3 是 int64 毫秒	已修复	6253e9b

3.3 P2 级 (改进建议)

编号	问题	状态
P2-1	HOST_COLLECTION_FALLBACK_ 硬编码 example.com 应从配置文件加载	保留
P2-2	测试覆盖不全: detector_service/mapper/consumer/producer/wal 无单元测试 (9/17 模块无测试)	保留
P2-3	AktoAdapter 在 main.cc 构造但从未调用 (死代码) 浪费 DLQ 连接资源	保留
P2-4	Metadata proto 为空 Akto 新版可能依赖此字段	保留
P2-5	response_status 格式 '403' vs '200 OK' Akto status 是 string, 功能正确但展示不友好	保留
P2-6	inferAttackType 'rce' 前缀匹配仍可能误判 如 'rcelog' 会匹配	保留

4. 安全维度评估

维度	评级	说明
内存安全	A	智能指针为主 (make_shared 17处), 无裸 new/delete RAII: DIR*/FILE* 用 unique_ptr 包装 WAL: fflush+fsync 崩溃安全
并发安全	A-	mutex + condition_variable 正确使用 (21处) 原子操作 memory_order 正确 (acquire/release/relaxed) CAS 防护 start/stop 重复调用 扣分: IpRateLimiter static 局部变量非线性安全 (call_counter)
整数安全	A	INT_MAX 溢出检查 (protobuf ParseFromArray) drain_timeout_ms 溢出保护 stoi 全部有 try-catch 保护 (2处)
错误处理	A-	std::expected 错误传播 (C++23) catch(std::exception) 33处 + catch(...) 13处 WAL fsync 失败不崩溃, 记录日志继续 扣分: 部分异常路径缺少 metrics 计数
输入验证	B+	protobuf INT_MAX 检查 sscanf 宽度限制 (%4d/%2d) JSON 转义防注入 (escapeJson) 扣分: WAL 文件名无路径遍历检查 (d_name 直接拼接)
DoS 防护	A	有界队列背压 (max_pending_tasks) IP 级限流 (5条/分钟) 告警分级过滤 (丢弃 LOW/RateLimit) Per-task 超时 (协作式)
编译严格	A+	-Wall -Wextra -Wpedantic -Werror ASAN + UBSAN (Debug 模式) C++23 标准
测试覆盖	B	124 用例 / 13 文件 E2E 管道测试 + 并发测试 扣分: 9/17 模块无单元测试

5. 关键设计决策评估

决策	评估	理由
C++23 + std::expected	正确	编译时类型安全错误处理，避免异常开销和遗忘检查
Pimpl 模式 (LogMapper)	正确	隐藏依赖，加快编译速度
WAL Write-Ahead Log	正确	fflush+fsync 确保崩溃安全，WAL Relay 异步重放
Kafka EOS (CTP 模式)	正确	事务原子性: 消费→检测→发送→提交 offset
有界阻塞队列 + 背压	正确	防止 OOM，submitBatch 阻塞等待
协作式超时 (非 std::future)	正确	在各步骤间插入 timed_out() 检查，避免线程开销
RE2 而非 std::regex	正确	RE2 线性时间，无 ReDoS 风险；std::regex 仅用于 config_loader
serializeAlert 中 proto 转换	正确	在发送前转换 WgeAlertEvent→MaliciousEventKafkaEnvelope AlertBuilder 负责填充字段，serializeAlert 负责格式转换
shouldSendAlert 保护逻辑	正确	在 sendAlert 前执行过滤/限流/兜底，三层保护
AktoAdapter::convert() deprecated	正确	死代码标注 deprecated，逻辑迁移到 WorkerPool
Proto EventType 同文件定义	可接受	与 Akto import 方式不同，但 wire format 兼容 后续可改为 import 保持 proto 文件一致
HOST_COLLECTION_FALLBACK 需硬编码	需硬编码	生产环境需要从配置文件或 Akto API 动态加载

6. 危险函数搜索

模式	出现次数	安全评估
memcpy/strcpy/strcat	0	无 C 风格字符串操作
sprintf (无长度限制)	0	全部使用 snprintf
snprintf	3	全部使用 sizeof(buf) 限制长度
atoi	0	使用 std::stoi + try-catch
system()/popen()	0	无命令执行
gets()	0	无使用
std::regex	2	仅 config_loader.cc 环境变量替换, thread_local 缓存
RE2	5	线性时间正则, 无 ReDoS 风险
value_unsafe() (simdjson)	0	全部使用安全的 value() 方法
裸 new/delete	0	全部使用 make_unique/make_shared
C 风格类型转换	0	全部使用 static_cast
sscanf	9	全部有宽度限制 (%4d/%2d) + 返回值检查

评估: 代码无高危危险函数调用, C++ 最佳实践遵循度高。

7. 改进建议

7.1 短期 (1-2 周)

优先级	建议	工作量
高	清理 main.cc 中 AktoAdapter 死代码 移除未使用的 akto_adapter 构造和 DLQ 连接	0.5 天
高	HOST_COLLECTION_FALLBACK_ 配置化 从 wge-detector.yaml 加载 Host→CollectionID 映射	1 天
中	补充 detector_service 单元测试 覆盖 start/stop/submitBatch 生命周期	2 天
中	补充 mapper.cc AktoProtobuf 路径测试 验证 akto_vxlan_id→collection_id 映射	1 天
中	WAL 文件名安全: 过滤 d_name 中的 ../ 和 /	0.5 天

7.2 中期 (1-2 月)

优先级	建议	工作量
高	补充 consumer/producer/wal 单元测试 目标: 17 个模块全部有测试	1 周
中	IpRateLimiter call_counter 改为原子变量 当前 static 局部变量在多线程下有数据竞争	0.5 天
中	Metadata proto 补全 从 Akto sample_request/v1/message.proto 复制完整定义	0.5 天
低	inferAttackType 改为精确匹配 用 prefix-anchored 匹配替代 find()	0.5 天
低	response_status 格式统一 添加 HTTP 状态码→状态行映射 (403→'403 Forbidden')	0.5 天

8. 审计统计

统计项	数值
审计提交范围	147 commits
审计文件数	47 个 (src + adapters + proto)
审计代码行数	12,854 行
测试代码行数	8,971 行
测试用例数	124 个
测试文件数	13 个
P0 级问题 (已修复)	4 个
P1 级问题 (已修复)	6 个
P2 级问题 (保留)	6 个
危险函数检出	0 个 (高危)
整体评级	B+ (良好)

审计结论: WGE-Kafka Detector 项目核心逻辑扎实, C++23 最佳实践遵循度高, 无高危安全漏洞。所有 P0/P1 级问题已在审计过程中修复。建议补充测试覆盖并清理死代码, 将评级提升至 A。